

HACKING WEBSITES

@OlsonTyler0



ETHICAL DISCLOSURE

Using tools that we will review in this project without explicit permission from the target organization is illegal and will get you arrested. Tools and learning is for demonstration purposes only and should only be done on machines you own or have permission to compromise.



WEB HACKING OVERVIEW

BREAKING DOWN HOW THE WEB FUNCTIONS

COMMON WEB VULNS

CTF APPLICATIONS

LAB: HACK A JUICE SHOP





Welcome to Amazon.com Books!

*[One million titles,](#)
[consistently low prices.](#)*

(If you explore just one thing, make it our [personal notification service](#). We think it's very cool! Also, check out [what our customers are saying about us](#).)

[SPOTLIGHT! -- JANUARY 16TH](#)

These are books we love, offered at Amazon.com low prices. The spotlight moves **EVERY** day so please come often.



[ONE MILLION TITLES](#)

Search Amazon.com's [million title catalog](#) by author, subject, title, keyword, and more... Or take a look at the [books we recommend](#) in over 20 categories... Check out our [customer reviews](#) and the [award winners](#) from the Hugo and Nebula to the Pulitzer and Nobel... and [bestsellers](#) are 30% off the publisher's list...



[EYES & EDITORS, A PERSONAL NOTIFICATION SERVICE](#)

Like to know when that book you want comes out in paperback or when your favorite author releases a new title? Eyes, our tireless, automated search agent, will send you mail. Meanwhile, our human editors are busy previewing galleys and reading advance reviews. They can let you know when especially wonderful works are published in particular genres or subject areas. Come in, [meet Eyes](#), and have it all explained.

[YOUR ACCOUNT](#)

Check the status of your orders or change the email address and password you have on file with us. Please note that you **do not** need an account to use the store. The first time you place an order, you will be given the opportunity to create an account.

[ABOUT AMAZON.COM](#)

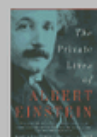
Here you can find such information as our everyday discounts (even paperbacks are usually 10% off), our returns policy, and the various ways to reach us, including our toll-free 800 number. If you're curious, you can also find out [why we're named Amazon.com...](#)

[EMPLOYMENT OPPORTUNITIES AT AMAZON.COM, INC.](#)

We have senior-level and entry-level openings, both of which include significant incentive stock options as part of the compensation package. If you're interested in the new juxtaposition of retailing and computers, please investigate the opportunities!

[[BUY ITEMS NOW](#) | [VIEW YOUR SHOPPING BASKET](#)]

[[Home](#) | [Browse the Shelves](#) | [Eyes & Editors](#) | [Your Account](#) | [Email Us](#) | [Help](#)]



[The Private Lives of Albert Einstein](#) by [Roger Highfield](#) and [Paul Carter](#)

"A deeply melancholic and moving tale that forces its readers to grapple with the enigma of the Einstein myth." -- *The Economist*

[More recommended Biographies](#)

Copyright © 1995 Amazon.com, Inc.
[webmaster@amazon.com](#)

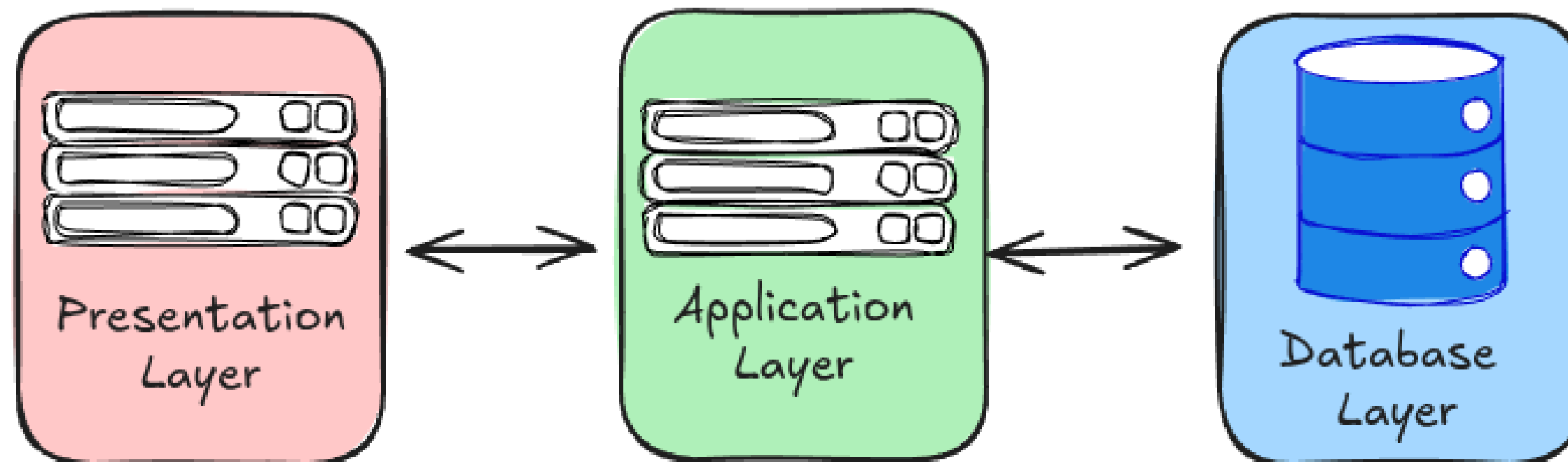
WHAT MAKES THE MAGIC?

- Web technology can be traced back to **Web 1.0** where most websites were static HTML.
 - **HyperText Markup Language (HTML)**
- **CSS, JavaScript**, and other languages emerged to add complexity, including style and interactivity (Clicking / forms, videos)
- Commonly refereed to as **Web 2.0** modern websites are focusing more on user generated content than ever. Posing more to companies than ever before.



HOW DO WEBSITES WORK?

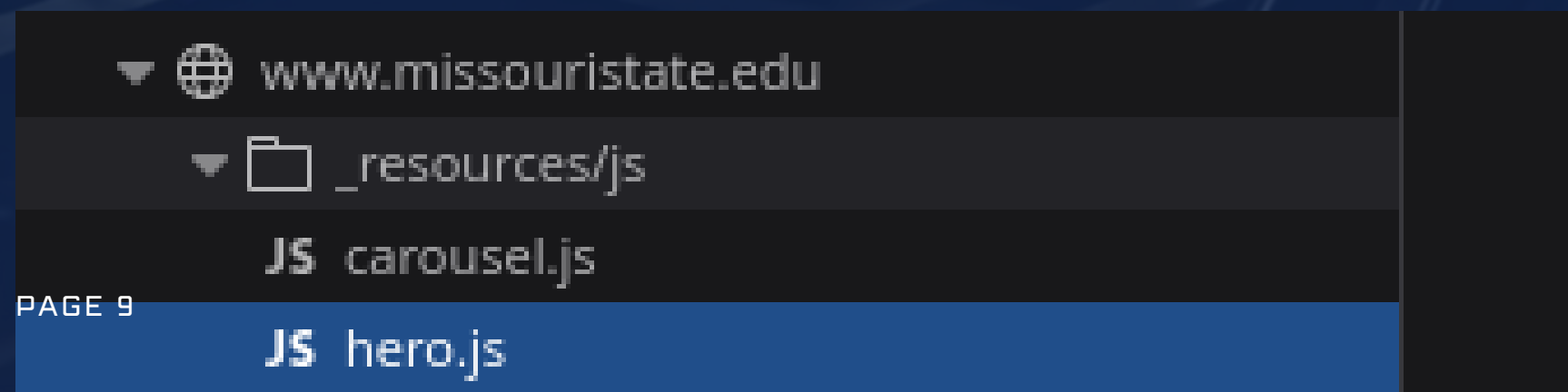
Three Layer Architecture



WHAT MAKES THE WEB WORK?

DIRECTORIES

- Websites under the hood are files that are served to the internet
- Website content is saved programatically in .html, .css, and .php files



Looking at a real example: Missouri state:

<https://missouristate.edu>

1. open developer tools (right click + inspect) → Debugger
- This allows you to find the directories and files loaded to present you the current content you are looking at.
2. Look for the *www.missouristate.edu* storage, you will see *_resources/js/hero.js*. This is a good code example we can look at!
 - This is hard to read because it is *minified* or *obfuscated*, its purposefully hard to read!
 - You can de-obfuscate with an online tool (see ctf tools github)
3. Now, naviagte to https://missouristate.edu/_resources/js/hero.js its the same code from before!



COMMON WEB VULNS

OWASP 2025 Top 10 List

<http://example.com/secrets.txt>

A01:2025 - Broken Access Control

A06:2025 - Insecure Design

Software Dev Lifecycle

Default accounts

A02:2025 - Security Misconfiguration

A:07:2025 - Authentication Failures

Brute force

Pollyfill.io

A03:2025 - Supply Chain Failures

A08:2025 - Software or Data Integrity Failures

Session Tokens

A04:2025 - Cryptographic Failures

A09:2025 - Security Logging and Alerting Failures

SQL Injection

A05:2025 - Injection

A:10:2025 - Mishandling of Exceptional Conditions



COMMON WEB VULNS



OWASP Top Ten Web Application Security Risks | OWASP Foundation

The OWASP Top 10 is the reference standard for the most critical web application security risks. Adopting the OWAS...

 owasp.org



WEB SHELLS

REMOTE CODE VIA WEBSITES

- A shell is a term used for a linux terminal, derived from the technology used in terminals.
- Web shells are typically a post-exploitation tool to retain access
- Malicious file uploads that are accessible can also cause this
 - if file validation isn't in place and a script can be used in place of an image file upload
 - <https://www.revshells.com/> is a spot to generate these.

TARGET LINUX:

<http://localhost/shell.php>



SOURCE CODE DE-OBFUSCATED HINTS

- You might be able to find HTML or PHP comments that might give you more information than the developer intends
 - Non scrapped websites,
 - development websites, etc
- Look back at the missouri state, can you see the comment about a feature that was disabled. with our knowledge before try to navigate to where that file should be stored. it seems to be code to run the alerts on the website!





Clicking a link
to an
interesting
article



"Please disable
adblock to
continue
viewing this
website"



```
html {  
  overflow-y: visible;  
}  
body, html, input
```

HACKING TOOLS

HACKER'S BEST FREIND

- Browser Development Tools
 - Intended for development use, but great to use for hackers
 - Look at: network, debugger, cookies
 - Can edit cookies aka your identifier to the server
- Burp Suite
 - Automated testing tool popular with pentesters,
 - Can take and edit requests on the fly

CAPTURE THE FLAG APPLICATION

- CTF's will usually use a one-solution path. can be from modifying what you are sending to the server to access and admin account, to accessing the base server.
- Look for low hanging fruit first.
 - What is the programming language used?
 - test common folders
 - /robots.txt - Shows places robots CANNOT go
 - /.git/
 - /admin
 - /login
 - Check the source code
 - Look at write ups / practice



LAB WEB HACKING

IN PERSON:

- Local machine setup at: [http://\(IP\):3000](http://(IP):3000)

ALTERNATIVE:

- ccdc.itccloud.top

POST:

- See the lab guide for installing and setting up a version of OWASP juice shop



LAB DIRECTORY TRAVERSAL

- Juice Shop provides some gamification, but we have to find the score board

The hints provided are:

- You missed the link during the initial mapping of the application
- There is a URL that leads to the Score Board but it is not hyperlinked to
- Knowing it exists, you can simply guess what URL the Score Board might have.
- Alternatively, you can try to find a reference or clue within the parts of the application that are not usually visible in the browser



LAB

SQL INJECTION + AUTH BYPASS

- The Juice shop has a account page, but it seems as it might be vulnerable to injection. see “injection” category on the scoreboard.
- You can launch the instructor, or attempt a SQL injection yourself



L A B

CROSS SITE SCRIPTING

- This ecommerce site provides a search bar! However, I wonder if it could be taken advantage of.
- If we can execute a script via the website that would be cool!
- SEE XSS category



LAB COOKIE MANIPULATION

- Sessions are stored in whats called “cookies” depending upon how these are secured by the website owner they can be vulnerable
- OBJECTIVE:
 - Look at how the dev tools recognize the cookies of the website. is there anything you can add? remove? change? does that break anything?
- NOTE: there is not a challenge here, just a simple look suffices



ADDITIONAL PRACTICE

OWASP JUICE SHOP

- Here ends our official guide, however it is a great place to look and learn about becoming a web hacker. there are several other labs OWASP also provides that can assist in your learning!



THANK YOU!



WHEN YOU GET ROOT IN THE FIRST 5 MINS TESTING